2026/2027

Estudio Teórico del Tema 1

CIB

JUAN MIGUEL DOMINUEZ PERDIGON
IES LOS SAUCES – DAW2

TEMA 1 FUNDAMENTOS DE CIBERSEGURIDAD

AMENAZAS Y VULNERABILIDADS INFORMATICAS..... 2
MEDIDAS DE PROCTECCIÓN BÁSICAS..... 3
ANALISIS DE LOS INCIDENTES DE SEGURIDAD..... 4
HERRAMIENTAS Y TECNOLOGIAS DE APLICACIÓN 6
NORMATIVA Y BUENAS PRACTICAS DE USO..... 7
AUDITORIA DE CIBERSEGURIDAD 8

AMENAZAS Y VULNERABILIDADS INFORMATICAS

1. Amenazas: un peligro latente o potencial de causar daño.
2. Vulnerabilidades: una debilidad o fallo en un sistema o red que puede ser explotado
3. Confidencialidad: cualidad de proteger los datos y la información para garantizar que solo las personas autorizadas puedan acceder a ellos
4. Integridad: cualidad de actuar en rectitud honestidad y total coherencia entre sus valores.
5. Disponibilidad: cualidad de estar listo para ser usado o accesible en un cualquier momento.
6. Malware: un programa informático malicioso creado para dañar, robar datos o tomar el control de un dispositivo sin permiso.
7. Ingeniería social: técnica que usan los ciberdelincuentes para engañar a las personas y conseguir información confidencial.
8. DoS y DDoS: ciberataque en el cual se satura un servidor web con falso tráfico de internet. Diferencia Dos usa una sola fuente para el ataque mientras que DDoS usa varias fuentes para el ataque.
9. Man-in-the-Middle: Una amenaza cibernética en la cual el intercepta, lee y altera las comunicaciones entre dos señales (persona con persona o cliente con aplicación).
10. Exploits: un programa desarrollado que se aprovechan de un bug de seguridad o vulnerabilidad.
11. Inyección SQL: cuando un agresor inserta instrucciones SQL maliciosas en campos de entrada para manipular la base de datos.
12. Cross-site Scripting (XSS): cuando un atacante inyecta código malicioso, generalmente JavaScript, en un sitio web de confianza.
13. Cifrar: Un proceso secreto, algoritmo o conjunto de reglas utilizado para encriptar y desencriptar datos. Diferencia entre http y https
14. Ransonmware: un tipo de software malicio el cual de prohíbe usar tu computadora o encripta los datos, demanda dinero para devolver el acceso.

MEDIDAS DE PROCTECCIÓN BÁSICAS

1. Autenticación Multifactor (MFA): Un proceso el cual requiere usar una o as formas de verificar tu identidad antes de acceder a una cuenta, aplicación o red.
2. Roles: una serie de permisos, responsabilidades o funciones asignadas a un usuario o sistemas.
3. Permisos: reglas de seguridad que deciden que usuario, programa o sistema pueden ver, cambiar, o ejecutar un archivo, directorio o funcionalidad de dispositivo.
4. Firewall: un sistema de seguridad que monitorea y controla el tráfico que entra y sale de una red.
5. Reglas de firewall: las instrucciones de seguridad que le dicen al firewall si permitir o bloquear datos en la red.
6. Filtrado datos o tráfico de red que han pasado por una reglas o sistema que elimina partes no deseadas.
7. Puertos: el punto final virtual o físico donde se inician, finalizan o atraviesan conexiones de red y comunicaciones de datos.
8. Protocolos: un conjunto estandarizado de reglas y formatos que determina como se trasmiten, reciben y procesan los datos entre diferentes dispositivos o sistemas de software.
9. Routers: un dispositivo que conecta dos más redes de computadoras y dirige el tráfico entre ellas.
10. Monitoreo: el Proceso continuo de recopilación, seguimiento y análisis de datos y métricas de rendimiento.
11. Auditoria: un examen formal y sistemático de la infraestructura de tecnología de la información, las políticas, las operaciones y los controles de una organización.

ANALISIS DE LOS INCIDENTES DE SEGURIDAD

1. Incidentes de Seguridad: cualquier evento que lastimé o amenacé lastimar la confidencialidad o integridad de una red o datos.
2. Ciclo de vida de un incidente: realizar el seguimiento de una incidencia desde el momento en que se produce o se notifica hasta que se resuelve y se cierra.
3. Detección: Identificación de señales que indican que puede estar ocurriendo un incidente.
4. Análisis del incidente: Investigación para conocer qué ha ocurrido, cómo se produjo, qué sistemas afecta y cuál es su alcance.
5. Contención. Medidas inmediatas para limitar la propagación o el daño de un incidente.
6. Erradicación: Eliminación de la causa del incidente, como malware, cuentas comprometidas o vulnerabilidades aprovechadas.
7. Recuperación: Restablecimiento seguro de los sistemas y servicios a su funcionamiento normal.
8. Aprendizaje: Conclusiones obtenidas tras gestionar un incidente que permiten mejorar procedimientos y reducir la posibilidad de repetición.
9. Incidente interno: Incidente originado por una persona, cuenta, dispositivo o proceso dentro de la organización, de forma accidental o deliberada.
10. Incidente externo: Incidente provocado desde fuera de la organización, por ejemplo, por un atacante externo.
11. Incidente dirigido: Ataque que se prepara para una persona, sistema u organización concretos.
12. Incidente masivo: Ataque o campaña que afecta a numerosos usuarios, equipos u organizaciones.
13. Naturaleza del incidente: Tipo de suceso según lo ocurrido, como malware, acceso no autorizado, fuga de datos o interrupción de servicio.
14. .Indicador de compromiso (IoC) : Evidencia observable que puede señalar que un sistema ha sido comprometido.
15. IoC basado en red: Indicador observado en comunicaciones, como una dirección IP sospechosa, un dominio malicioso o tráfico inusual.
16. IoC basado en sistema: Indicador local, como un archivo desconocido, un proceso anómalo o un cambio inesperado de configuración.
17. IoC basado en registros: Evento o patrón encontrado en logs que puede indicar una intrusión o actividad maliciosa.
18. Sistema de detección de intrusos (IDS) : Herramienta que supervisa sistemas o redes para identificar actividad sospechosa y generar alertas.
19. Sistema de prevención de intrusos (IPS) : Herramienta que detecta actividad maliciosa y puede bloquearla o detenerla automáticamente.

20. Mitigación de riesgos: Aplicación de medidas para reducir la probabilidad de que ocurra un riesgo o limitar sus consecuencias.
21. Análisis coste-beneficio: Comparación de los costes de una medida de seguridad con los beneficios y la reducción de riesgo que aporta.
22. Viabilidad técnica: Grado en que una medida puede implantarse con los sistemas, recursos y conocimientos técnicos disponibles.
23. Viabilidad operativa: Grado en que una medida puede mantenerse y utilizarse en las operaciones habituales de la organización.
24. Informe de incidente: Documento que recoge qué sucedió, su impacto, las evidencias, las acciones realizadas y las recomendaciones.
25. Análisis forense digital: Examen metódico de dispositivos, archivos y comunicaciones para identificar y documentar evidencias digitales.

HERRAMIENTAS Y TECNOLOGIAS DE APLICACIÓN

1. Herramienta de ciberseguridad. Programa o dispositivo que ayuda a prevenir, detectar, analizar o responder ante amenazas informáticas.
2. Firewall de red. Cortafuegos situado en un punto de la red para filtrar comunicaciones entre redes o segmentos.
3. Firewall de host. Cortafuegos instalado en un equipo concreto que controla el tráfico entrante y saliente de ese equipo.
4. IDS. Sistema de detección de intrusos que analiza eventos o tráfico y alerta cuando identifica indicios de actividad maliciosa.
5. IPS. Sistema de prevención de intrusos que, además de detectar amenazas, puede tomar medidas para bloquearlas.
6. Antivirus. Software que identifica, bloquea o elimina programas maliciosos mediante firmas, análisis de comportamiento y otras técnicas.
7. Antimalware. Herramienta orientada a detectar y combatir distintas clases de software malicioso; el término puede abarcar funciones de antivirus.

NORMATIVA Y BUENAS PRACTICAS DE USO

1. Reglamento General de Protección de Datos (RGPD). Reglamento de la Unión Europea que regula el tratamiento de datos personales y protege los derechos y libertades de las personas.
2. ISO/IEC 27001. Norma internacional que establece requisitos para crear, implantar, mantener y mejorar un sistema de gestión de seguridad de la información.
3. Esquema Nacional de Seguridad (ENS). Marco español de requisitos y medidas de seguridad para proteger la información y los servicios electrónicos dentro de su ámbito de aplicación.
4. Dato sensible. Información que requiere especial cuidado por su naturaleza o por las consecuencias que tendría su divulgación o uso indebido. En protección de datos, determinadas categorías tienen una protección legal específica.
5. Clasificación de datos. Proceso de organizar la información según su sensibilidad, importancia y necesidades de protección.
6. Política de acceso. Reglas que determinan quién puede consultar o modificar información y en qué circunstancias.
7. Ciclo de vida de la información. Etapas por las que pasa la información, desde su creación o recopilación hasta su uso, almacenamiento, archivo y eliminación.
8. Evaluación de seguridad. Revisión de medidas y controles para determinar si protegen adecuadamente los sistemas y la información.
9. Diagnóstico de fallos. Proceso de identificar el origen y las características de un problema o debilidad de seguridad.
10. Gestión de riesgos. Proceso de identificar, analizar, evaluar y tratar los riesgos que pueden afectar a los sistemas o a la información.
11. Identificación de riesgos. Reconocimiento de situaciones que podrían provocar daños o pérdidas.
12. Evaluación de riesgos. Estimación de la probabilidad y las consecuencias de cada riesgo para decidir su prioridad y tratamiento.
13. Plan de acción. Documento que concreta las medidas que se van a aplicar, sus responsables, prioridades y plazos.
14. Mejora continua. Revisión periódica de controles y procedimientos para corregir deficiencias y adaptarse a nuevas amenazas y necesidades.
15. Registro de incidencias. Historial de problemas y sucesos de seguridad, con información sobre su detección, tratamiento y resolución.

AUDITORIA DE CIBERSEGURIDAD

Mario Celadas Matias

shodan-Navegador Web: